

Manual 19 — Implementação Controlada de FedRAMP / FISMA

Localização controlada pt-BR — candidata assistida por máquina

****Ordem da série:**** 19

****Fonte inglesa congelada:**** blob `6dc279577768f23f9c2d799b04a0544fa1bfe1c4`

****Limite:**** Somente orientação de implementação. Manter separados o estatuto FISMA, as políticas OMB/CISA, a orientação NIST, os requisitos do programa FedRAMP, os requisitos específicos de agências e os procedimentos organizacionais. Não afirmar que uma certificação FedRAMP, por si só, estabelece autorização de uma agência ou conformidade geral com FISMA. Esta localização não é tradução oficial. A revisão semântica humana só é requisito de publicação quando houver uma questão substantiva específica e documentada que exija julgamento humano não determinístico; caso contrário, aplica-se a regra canônica de publicação automática para candidatos sem erros nem questões pendentes.

1. Governança federal, propósito e aplicabilidade

Definir escopo do sistema/serviço, relações com clientes federais, organizações responsáveis, estatutos/políticas aplicáveis, caminho de autorização e executivos responsáveis. Evidência: memorando de aplicabilidade, charter de governança, registro de fontes e decisão do caminho de autorização. Reavaliar após mudanças de cliente, serviço, impacto ou política.

2. Contexto estatutário da FISMA

Manter mapa de fontes legais e de política identificando quais obrigações decorrem da FISMA e quais decorrem de política ou orientação de implementação. Atribuir responsabilidade pela interpretação legal/política. Evidência: análise de aplicabilidade estatutária e referência cruzada de políticas. Não apresentar orientação como texto estatutário.

3. Contexto do programa e autorização FedRAMP

Determinar se o serviço segue um caminho Rev. 5 vigente, uma classe de certificação FedRAMP 20x, processo de autorização conduzido por agência ou outra rota oficialmente suportada. Evidência: decisão de caminho, registro de patrocinador/cliente, status no Marketplace e plano de transição. Reverificar antes de marcos importantes.

4. Relação com o NIST Risk Management Framework

Usar o RMF como modelo de ciclo de vida de gestão de risco preservando a autoridade decisória específica da agência e do FedRAMP. Mapear Prepare, Categorize, Select, Implement, Assess, Authorize e Monitor a responsáveis e evidências. Testar rastreabilidade e atualidade das decisões.

5. Relação com a linha de base de controles SP 800-53

Manter a linha de base de controles aplicável e as fontes de parâmetros sem reproduzir material protegido ou obsoleto. Registrar tailoring, herança, overlays, parâmetros definidos pela organização e justificativa. Evidência: matriz de controles e proveniência da linha de base.

6. Categorização do sistema e análise de impacto

Documentar tipos de informação, análise de impacto de confidencialidade/integridade/disponibilidade, base de categorização e autoridade aprovadora. Evidência: planilha de categorização, inventário de dados e justificativa de impacto. Reavaliar após mudanças materiais de dados ou missão.

7. Limite de autorização e inventário de componentes

Definir limite de autorização, serviços externos, interconexões, serviços herdados, ambientes, componentes, fluxos de dados e ativos excluídos. Evidência: diagrama do limite, inventário, interfaces e justificativa. Comparar descoberta técnica com a documentação.

8. Seleção e tailoring de controles

Selecionar controles com base no caminho aplicável, nível/classe de impacto, requisitos da agência, risco e regras FedRAMP vigentes. Registrar adições, remoções, tailoring, parâmetros, herança e aprovações. Evidência: conjunto de controles ajustado e registro de decisões.

9. Overlays e requisitos específicos de agências

Identificar overlays e requisitos de cliente/agência separadamente dos controles gerais do programa. Evidência: registro de overlays e mapeamento contratual/de agência. Evitar generalizar requisitos locais para clientes não relacionados.

10. Declarações de implementação de controles

Redigir declarações que identifiquem componente responsável, procedimento, frequência/gatilho, evidência, herança e exceções. Evitar linguagem aspiracional sem evidência operacional. Testar amostras contra configurações e procedimentos reais.

11. Papéis, responsabilização e segregação de funções

Definir papéis de CSP, agência, avaliador, autoridade autorizadora, proprietário do sistema, segurança, privacidade, operações, engenharia e prestadores. Evidência: RACI, charters, delegações e controles de conflito de interesse. Preservar limites de julgamento de autorização e avaliação independente.

12. Identidade, acesso e administração privilegiada

Implementar ciclo de vida de identidades, menor privilégio, MFA, PAM, governança de contas de serviço, revisões periódicas e acesso de emergência. Evidência: registros de acesso, logs PAM, cobertura MFA e resultados de revisão. Testar acessos inativos, excessivos e não gerenciados.

13. Gestão de configuração e mudanças

Manter baselines aprovadas, padrões de configuração, aprovações de mudança, mudanças emergenciais, detecção de drift e rollback. Evidência: baselines, varreduras, tickets e exceções. Mudanças significativas devem acionar análise de impacto de autorização.

14. Gestão de vulnerabilidades e patches

Definir cobertura de varredura, priorização por severidade/risco, prazos de remediação, exceções, validação e reporte. Evidência: resultados de varredura, tickets, decisões de risco e retestes. Monitorar envelhecimento e recorrência de vulnerabilidades.

15. Registro, monitoramento e detecção

Definir fontes de eventos, sincronização de tempo, retenção, proteção, casos de uso de detecção, responsabilidade por alertas, escalonamento e disponibilidade de evidência. Evidência: padrão de logging, cobertura SIEM e amostras de alertas/tickets. Testar detecções representativas ponta a ponta.

16. Resposta a incidentes e interfaces de reporte federal

Manter identificação, contenção, recuperação, preservação de evidência, escalonamento a cliente/agência e fluxos federais aplicáveis. Evidência: plano IR, matriz de contatos, exercícios e registros de incidentes. Reverificar requisitos de reporte quando a política mudar.

17. Planejamento de contingência e resiliência

Alinhar impacto de negócio, backup, recuperação, processamento alternativo, comunicações e segurança durante a recuperação. Evidência: plano de contingência, resultados de teste, métricas de recuperação e validação de backups. Impedir que recuperação emergencial contorne silenciosamente controles requeridos.

18. Controles criptográficos e gestão de chaves

Definir uso criptográfico aprovado, ciclo de vida de chaves, certificados, segredos, criptografia em trânsito/em repouso e exceções conforme requisitos federais aplicáveis. Evidência: inventário criptográfico, registros de chaves, amostras de configuração e aprovações de exceção.

19. Cadeia de suprimentos e risco de terceiros

Governar serviços externos, software, componentes, subcontratados, controles herdados, proveniência, incidentes e risco de concentração. Evidência: inventário de fornecedores, due diligence, contratos, SBOM/registros de componentes quando aplicável e resultados de monitoramento.

20. Serviço em nuvem e limites de responsabilidade compartilhada

Mapear responsabilidades do provedor, CSP, cliente/agência e serviços externos para cada controle relevante. Evidência: matriz de responsabilidades, declarações de herança e evidência de arquitetura. Testar lacunas criadas por responsabilidades presumidas.

21. Desenvolvimento seguro e ciclo de vida do sistema

Integrar requisitos de segurança/privacidade em design, código, dependências, build/release, segredos, testes, implantação e desativação. Evidência: registros SDLC, testes de segurança, evidência de dependências e aprovações de release. Releases significativos exigem revisão de impacto de autorização.

22. Planejamento de avaliação e coleta de evidências

Definir escopo, procedimentos, amostragem, solicitações de evidência, repositórios, cadeia de custódia e tratamento de achados. A evidência deve ser atual, reproduzível, atribuível e mapeada às declarações de implementação. Automação pode apoiar, mas não substitui julgamento do avaliador.

23. Independência do avaliador e limites da avaliação

Documentar requisitos aplicáveis de qualificação e independência para o caminho de autorização/certificação selecionado. Separar apoio de readiness de conclusões que exigem avaliação independente. Evidência: escopo do trabalho, registro de independência/competência e plano de avaliação.

24. Achados, POA&M e governança de remediação

Registrar achado, severidade/risco, causa raiz, responsável, marcos, salvaguardas compensatórias, datas, evidência, validação e autoridade de encerramento. Evidência: registro POA&M/achados e retestes. Impedir encerramento administrativo sem evidência objetiva de remediação.

25. Arquitetura do pacote de autorização

Manter componentes autorizados do pacote, propriedade, versionamento, verificações de consistência e status de envio/revisão. Separar preparação de evidência das decisões de autorização. Evidência: índice do pacote, SSP/componentes, resultados de avaliação e decisões aplicáveis.

26. OSCAL e conceitos de pacote legível por máquina

Usar OSCAL ou outras estruturas oficialmente suportadas quando aplicável para melhorar consistência e automação. Preservar significado legível por humanos, proveniência, versão de schema e validação. Automação deve falhar de forma fechada em transformações inválidas ou incompletas.

27. Monitoramento contínuo

Definir monitoramento recorrente de controles, atualizações de vulnerabilidade/configuração, atualização de evidências, reporte, revisão de risco e interfaces com clientes/agências. Evidência: plano de monitoramento contínuo, entregas recorrentes, métricas, achados e registros de mudança.

28. Mudanças significativas e gatilhos de reavaliação

Definir gatilhos como mudanças de arquitetura, limite, identidade, criptografia, dados, hosting, versão principal, aquisição, incidente, fornecedor ou caminho de autorização. Evidência: avaliações de impacto e decisões de reautorização/reavaliação.

29. Pontos de decisão da transição FedRAMP 20x / Rev. 5

Manter registro datado da transição. Conforme a verificação de fonte controlada: 20x Fase 3 está ativa; Classe A abriu em 3 de agosto de 2026; pipelines Classe B/Classe C estão programados para 31 de agosto de 2026; novas certificações Rev. 5 têm meta de término em 11 de junho de 2027; e a adoção obrigatória de Consolidated Rules 2026 é indicada para 1º de janeiro de 2027, sujeita à aplicabilidade específica. Reverificar todas as datas antes do release e do uso operacional.

30. Manutenção de certificação e autorização

Acompanhar condições contínuas, status de Marketplace/programa quando aplicável, condições de autorização da agência, avaliações recorrentes, monitoramento, remediação e notificações de mudança. Evidência: calendário, entregas, decisões e registros de status. Não descrever manutenção de certificação como substituto da aceitação de risco pela agência.

31. Controle de fontes, mudanças de política e datas de vigência

Monitorar fontes oficiais FedRAMP, NIST, OMB, CISA, estatutárias e de agências relevantes. Registrar URL, data de publicação/vigência, aplicabilidade, impacto, responsável e mudanças requeridas. Mudanças materiais reabrem as revisões e gates afetados.

32. Localização, QA renderizado, proveniência e controles de release

Congelar a fonte inglesa exata antes das localizações es-419 e pt-BR. Preservar terminologia federal e distinguir localizações não oficiais do texto fonte autoritativo. Antes da publicação exigir estrutura/paridade, revisões humanas substantivas documentadas quando requeridas, inspeção renderizada/de páginas/acessibilidade, seis DOCX/PDF reproduzíveis, SHA-256 exatos, staging durável, segurança de workflow, QA do pacote, reverificação de fontes, publicação do predecessor e reconciliação de catálogo/registo.

Limite de release controlado

Este master localizado em desenvolvimento não é certificação FedRAMP, autorização de agência, atestação FISMA, determinação legal nem declaração de publicação. O release permanece fail-closed sob os controles do repositório e a ordem sequencial de publicação.